

Vertrag zur Auftragsverarbeitung (AVV) gemäß Art. 28 DSGVO

Terminkalender „Zsuzsanna Nagelstudio“ — kalender.nex-a-i.com

Stand: September 2026

Dieser Vertrag zur Auftragsverarbeitung (nachfolgend "AVV") regelt die Verarbeitung personenbezogener Daten, die NexAI im Rahmen der Bereitstellung und des Betriebs des Terminkalenders für die Kundin durchführt. Er gilt eigenständig; besteht daneben ein Rahmen- oder Dienstleistungsvertrag, ist dieser AVV dessen Bestandteil.

Parteien

Auftragsverarbeiter: NexAI – Next Generation Artificial Intelligence GbR, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt, Deutschland, vertreten durch die Gesellschafter Maximilian Trenk und Jason Brian Merklein, E-Mail mbt@nex-a-i.com, Telefon 0176 80714816 — nachfolgend "NexAI".

Verantwortliche (Kundin): Zsuzsanna Schatz, Zsuzsanna Nagelstudio, Dinkelsbühlerstr. 10, 74579 Unterdeufstetten, Deutschland, E-Mail kincs.zsuzsa@gmail.com, Telefon +49 172 8236267 — nachfolgend "Kundin".

NexAI und die Kundin nachfolgend gemeinsam "Parteien", einzeln "Partei".

Gegenstand und Rollenverteilung

- (1) NexAI entwickelt und betreibt für die Kundin einen Terminkalender, bestehend aus einer öffentlichen Buchungsseite für deren Kundschaft und einer Verwaltungsoberfläche für die Kundin (nachfolgend "Terminkalender"). Im Rahmen dieses Betriebs verarbeitet NexAI personenbezogene Daten im Auftrag der Kundin.
- (2) Die Kundin ist hinsichtlich der im Auftrag verarbeiteten personenbezogenen Daten **Verantwortliche** im Sinne des Art. 4 Nr. 7 DSGVO. NexAI ist insoweit **Auftragsverarbeiterin** im Sinne des Art. 4 Nr. 8 DSGVO.
- (3) Die Kundin entscheidet allein über Zwecke und Mittel der Verarbeitung, insbesondere darüber, welche Leistungen angeboten, welche Öffnungszeiten hinterlegt und welche Angaben von der Kundschaft erhoben werden.
- (4) NexAI verarbeitet die Daten nicht zu eigenen Zwecken. Für die eigene Geschäftsbeziehung zur Kundin (Vertragsabwicklung, Abrechnung, Kontakt) ist NexAI eigene Verantwortliche; diese Verarbeitung ist nicht Gegenstand dieses AVV.

Art, Umfang, Zweck und Dauer der Verarbeitung

- (1) **Art der Verarbeitung:** Erheben, Speichern, Ordnen, Verändern, Auslesen, Übermitteln (Versand von Bestätigungen und Erinnerungen), Einschränken, Löschen und Vernichten.
- (2) **Zweck:** Vereinbarung, Verwaltung und Nachweis von Terminen der Kundin sowie die damit verbundene Benachrichtigung ihrer Kundschaft. Ferner die Ausstellung von Belegen über erbrachte Leistungen und deren Aufbewahrung nach steuerrechtlichen Vorgaben.
- (3) **Umfang:** Betrieb des Terminkalenders einschließlich Datenbank, Buchungsseite, Verwaltungsoberfläche, Nachrichtenversand, Datensicherung und Wartung.

- (4) **Dauer:** Der AVV gilt für die Laufzeit der zugrunde liegenden Leistungsbeziehung. Er endet mit deren Beendigung; § 12 (Löschung und Rückgabe) bleibt davon unberührt.

Kategorien betroffener Personen und personenbezogener Daten

3.1 Kategorien betroffener Personen

- **Kundschaft der Kundin** — Personen, die einen Termin buchen, telefonisch vereinbaren oder als Laufkundschaft eingetragen werden;
- die Kundin selbst und weitere von ihr angelegte Zugänge als Nutzerinnen und Nutzer der Verwaltungsoberfläche;
- Dritte, deren Daten von der Kundschaft im Anmerkungsfeld einer Buchung mitgeteilt werden.

3.2 Kategorien personenbezogener Daten

- **Stammdaten der Kundschaft:** Name, Telefonnummer (Pflichtangabe), E-Mail-Adresse (freiwillig), Anschrift (nur, soweit für einen Beleg erforderlich);
- **Terminaten:** Datum, Uhrzeit, Dauer, gebuchte Leistung, Preis, Zustand des Termins, Herkunft der Buchung;
- **freie Texte:** Anmerkung der Kundschaft bei der Buchung sowie interne Notizen der Kundin zum Termin oder zur Person;
- **Beleg- und Gutscheindaten:** Belegnummer, Datum, Positionen, Betrag, Empfängerangaben;
- **Nachrichtendaten:** Rufnummer bzw. E-Mail-Adresse der Empfängerin, Inhalt der Bestätigung oder Erinnerung, Zustellstatus;
- **Zugangs- und Protokolldaten:** Anmeldedaten der Kundin (Passwort ausschließlich als Prüfsumme), Sitzungen, Änderungsprotokoll, IP-Adresse im Zähler gegen missbräuchliche Buchungen.

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der beauftragten Verarbeitung. Der Terminkalender erhebt keine Gesundheitsdaten; das Anmerkungsfeld der Buchungsseite weist ausdrücklich darauf hin, dort keine gesundheitsbezogenen Angaben zu machen. Teilt eine betroffene Person solche Daten dennoch unaufgefordert mit, verarbeitet NexAI sie ausschließlich im Rahmen der dokumentierten Weisungen und der Löschfristen nach § 8.

Weisungsbindung

- (1) NexAI verarbeitet personenbezogene Daten ausschließlich auf **dokumentierte Weisung** der Kundin, es sei denn, NexAI ist nach Unionsrecht oder dem Recht eines Mitgliedstaats zur Verarbeitung verpflichtet (Art. 28 Abs. 3 lit. a DSGVO). In diesem Fall teilt NexAI der Kundin diese rechtliche Anforderung vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.
- (2) Die maßgeblichen Weisungen sind in diesem AVV und den übrigen Vertragsdokumenten festgelegt (Erstweisung). Weitergehende Einzelweisungen erteilt die Kundin in Textform gegenüber der in § 14 genannten Kontaktstelle. Mündliche Weisungen bestätigt die Kundin unverzüglich in Textform.
- (3) NexAI informiert die Kundin unverzüglich, wenn NexAI der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 Satz 3 DSGVO). NexAI ist berechtigt, die Durchführung der betreffenden Weisung bis zu deren Bestätigung oder Änderung durch die Kundin auszusetzen.

- (4) Die Kundin trägt die Verantwortung für die Rechtmäßigkeit der Weisungen und der Verarbeitung, insbesondere für das Vorliegen einer tragfähigen Rechtsgrundlage.

Vertraulichkeit

- (1) NexAI verpflichtet die mit der Verarbeitung befassten Personen zur Vertraulichkeit, soweit sie nicht bereits einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b, Art. 29, Art. 32 Abs. 4 DSGVO).
- (2) NexAI stellt sicher, dass Personen, die zur Verarbeitung der personenbezogenen Daten befugt sind, mit den einschlägigen datenschutzrechtlichen Anforderungen vertraut sind und Daten nur auf Weisung verarbeiten. Die Verpflichtung besteht auch nach Beendigung der Tätigkeit fort.
- (3) Als Gesellschafter der NexAI GbR sind Maximilian Trenk und Jason Brian Merklein unmittelbar zur Vertraulichkeit verpflichtet.

Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

- (1) NexAI trifft die zur Gewährleistung eines dem Risiko angemessenen Schutzniveaus erforderlichen technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO. Die zum Zeitpunkt des Vertragsschlusses getroffenen Maßnahmen sind in **Anhang 1 (Technische und organisatorische Maßnahmen)** beschrieben und sind Bestandteil dieses AVV.
- (2) NexAI ist berechtigt, die Maßnahmen an den Stand der Technik und an geänderte tatsächliche Verhältnisse anzupassen, sofern das vereinbarte Schutzniveau nicht unterschritten wird. Wesentliche Änderungen dokumentiert NexAI und stellt sie der Kundin auf Anfrage zur Verfügung.
- (3) NexAI überprüft die Wirksamkeit der Maßnahmen in angemessenen Abständen.

Zweckbindung

- (1) NexAI verarbeitet die personenbezogenen Daten der Kundin ausschließlich zu den in § 2 genannten Zwecken und nicht für eigene Zwecke.
- (2) NexAI verwendet die im Auftrag verarbeiteten personenbezogenen Daten **nicht zum Training, zur Weiterentwicklung oder zur Verbesserung eigener oder fremder KI-Modelle**. Im Terminkalender kommt kein Verfahren der künstlichen Intelligenz zum Einsatz; eine Übermittlung an Anbieter solcher Verfahren findet nicht statt.
- (3) Eine Auswertung der Daten erfolgt ausschließlich für die Kundin selbst (Auslastung, Umsatz, offene Belege) und nicht kundenübergreifend.
- (4) Eine über die Auftragserfüllung hinausgehende Verarbeitung durch NexAI zu eigenen Zwecken – insbesondere zur Produktverbesserung – erfolgt nur nach Anonymisierung oder auf gesonderter, dokumentierter Rechtsgrundlage (Art. 28 Abs. 10 DSGVO).

Speicherorte, Speicherdauer und Löschung

- (1) Die Verarbeitung erfolgt auf einem Server in einem Rechenzentrum der Hetzner Online GmbH in Deutschland. Weitere Empfänger ergeben sich aus **Anhang 2 (Unterauftragsverarbeiter)**.
- (2) Die Datensicherung erfolgt verschlüsselt auf einen zweiten Server in einem anderen deutschen Rechenzentrum. Der zur Entschlüsselung erforderliche private Schlüssel wird auf keinem der beiden Server aufbewahrt.
- (3) Die Löschfristen sind im Terminkalender als automatischer täglicher Lauf hinterlegt und entsprechen der Datenschutzerklärung der Kundin:

Daten	Frist
Stammdaten der Kundschaft (Name, Telefon, E-Mail, Notizen)	24 Monate nach dem letzten Termin; danach wird der Datensatz anonymisiert, der Termin bleibt ohne Personenbezug erhalten
Zähler gegen missbräuchliche Buchungen (enthält IP-Adressen)	7 Tage
Protokoll der verschickten Bestätigungen und Erinnerungen (Rufnummer, Nachrichtentext)	6 Monate nach Abschluss; noch nicht versandte Nachrichten bleiben bis zum Versand erhalten
Internes Änderungsprotokoll	24 Monate

Daten	Frist
Belege und Belegpositionen	8 Jahre ab Schluss des Kalenderjahres der Ausstellung (§ 147 Abs. 3, Abs. 4 AO, § 14b Abs. 1 UStG)

- (1) Von der Löschung ausgenommen sind Daten, deren weitere Aufbewahrung zur Erfüllung gesetzlicher Aufbewahrungspflichten erforderlich ist; solche Daten werden in ihrer Verarbeitung eingeschränkt (gesperrt) und nach Wegfall des Zwecks gelöscht.
- (2) **Ausgestellte Belege sind unveränderbar**; die Datenbank weist jede nachträgliche Änderung ab. Eine Korrektur erfolgt ausschließlich durch Storno und Neuausstellung. Ein Beleg überdauert deshalb auch die Anonymisierung der zugehörigen Kundendaten und trägt Name und Anschrift als eigene Kopie.
- (3) Zahlungsdaten werden **nicht** verarbeitet. Der Terminkalender erfasst keine Zahlungsvorgänge, keine Zahlarten und keine Bankverbindungen der Kundschaft.

Unterauftragsverarbeiter

- (1) Die Kundin erteilt NexAI die **allgemeine schriftliche Genehmigung** zur Beauftragung von Unterauftragsverarbeitern (Art. 28 Abs. 2 Satz 2 DSGVO). Die zum Zeitpunkt des Vertragsschlusses eingesetzten Subunternehmer sind in **Anhang 2 (Unterauftragsverarbeiter)** aufgeführt und werden hiermit genehmigt.
- (2) NexAI informiert die Kundin über beabsichtigte Änderungen in Bezug auf die Hinzuziehung oder Ersetzung von Unterauftragsverarbeitern **mindestens vierzehn (14) Tage vorab in Textform** (Art. 28 Abs. 2 Satz 1 DSGVO).
- (3) Die Kundin kann einer beabsichtigten Änderung binnen der Frist aus wichtigem, datenschutzbezogenem Grund in Textform **widersprechen**. Im Fall eines berechtigten Widerspruchs bemühen sich die Parteien um eine einvernehmliche Lösung. Kann diese nicht gefunden werden und ist NexAI die Erbringung der betroffenen Leistung ohne den Subunternehmer nicht mit zumutbarem Aufwand möglich, steht jeder Partei ein **Sonderkündigungsrecht** hinsichtlich der betroffenen Leistung mit angemessener Frist zu.
- (4) NexAI verpflichtet jeden Unterauftragsverarbeiter durch Vertrag oder anderes Rechtsinstrument auf Datenschutzpflichten, die den Pflichten dieses AVV im Wesentlichen entsprechen, insbesondere auf hinreichende Garantien nach Art. 28 Abs. 3 und Abs. 4 DSGVO. Kommt der Unterauftragsverarbeiter seinen Datenschutzpflichten nicht nach, haftet NexAI gegenüber der Kundin für die Einhaltung dieser Pflichten.
- (5) Nicht als Unterauftragsverarbeitung im Sinne dieser Regelung gelten Nebenleistungen, die NexAI als Nebenleistung in Anspruch nimmt (z. B. Telekommunikations-, Post-/Transport-, Wartungsleistungen), sofern dabei kein Zugriff auf die im Auftrag verarbeiteten Daten zum Zweck der Verarbeitung erfolgt.

Drittlandtransfer

- (1) Die Verarbeitung findet ausschließlich in der Bundesrepublik Deutschland statt. Ein Transfer in ein Drittland erfolgt in der zum Zeitpunkt des Vertragsschlusses eingerichteten Konfiguration **nicht**.
- (2) Wird auf Weisung der Kundin künftig ein Dienst mit Sitz oder Verarbeitung in einem Drittland eingesetzt (etwa für den Versand von E-Mails), stellt NexAI sicher, dass die Anforderungen der Art. 44 ff. DSGVO eingehalten werden — vorrangig durch einen Angemessenheitsbeschluss der Europäischen Kommission, hilfsweise durch die EU-Standardvertragsklauseln (Durchführungsbeschluss (EU) 2021/914) nebst Transfer-Folgenabschätzung.
- (3) NexAI informiert die Kundin über einen solchen Wechsel nach Maßgabe des § 9 Abs. 2 vorab und stellt Nachweise über die getroffenen Transfergarantien auf Anfrage zur Verfügung.

Unterstützungspflichten

11.1 Betroffenenrechte

- (1) NexAI unterstützt die Kundin mit geeigneten technischen und organisatorischen Maßnahmen, soweit möglich, bei der Erfüllung von Anträgen betroffener Personen auf Wahrnehmung ihrer Rechte nach Art. 12–23 DSGVO (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch).
- (2) Wendet sich eine betroffene Person unmittelbar an NexAI, leitet NexAI das Anliegen unverzüglich an die Kundin weiter und beantwortet es nicht selbständig, es sei denn, die Kundin weist dies an.

11.2 Meldung von Datenschutzverletzungen

- (1) NexAI meldet der Kundin jede Verletzung des Schutzes personenbezogener Daten **unverzüglich, spätestens jedoch innerhalb von vierundzwanzig (24) Stunden nach Kenntniserlangung**, in Textform (Art. 33 Abs. 2 DSGVO).
- (2) Die Meldung enthält, soweit verfügbar, eine Beschreibung der Art der Verletzung, die Kategorien und die ungefähre Zahl der betroffenen Personen und Datensätze, die wahrscheinlichen Folgen sowie die ergriffenen oder vorgeschlagenen Abhilfemaßnahmen. Soweit die Informationen nicht zeitgleich bereitgestellt werden können, dürfen sie ohne unangemessene weitere Verzögerung schrittweise nachgereicht werden.
- (3) NexAI unterstützt die Kundin bei dessen Melde- und Benachrichtigungspflichten nach Art. 33 und Art. 34 DSGVO und ergreift angemessene Maßnahmen zur Eindämmung und Behebung.

11.3 Datenschutz-Folgenabschätzung

- (1) NexAI unterstützt die Kundin unter Berücksichtigung der Art der Verarbeitung und der verfügbaren Informationen bei einer Datenschutz-Folgenabschätzung (Art. 35 DSGVO) sowie bei einer vorherigen Konsultation der Aufsichtsbehörde (Art. 36 DSGVO).

11.4 Vergütung von Unterstützungsleistungen

Unterstützungsleistungen nach diesem § 11, die über den vertraglich geschuldeten Umfang hinausgehen und nicht auf einem NexAI zuzurechnenden Umstand beruhen, kann NexAI nach vorheriger Ankündigung zu den vereinbarten bzw., soweit nicht vereinbart, den üblichen Sätzen abrechnen. Die gesetzlich geschuldeten Grundunterstützungspflichten nach Art. 28 Abs. 3 DSGVO bleiben unentgeltlich.

Löschung und Rückgabe nach Beendigung

- (1) Nach Abschluss der Erbringung der Verarbeitungsleistungen löscht NexAI nach Wahl der Kundin alle personenbezogenen Daten oder gibt sie zurück und löscht vorhandene Kopien, sofern nicht nach Unionsrecht oder mitgliedstaatlichem Recht eine Verpflichtung zur Speicherung besteht (Art. 28 Abs. 3 lit. g DSGVO).
- (2) NexAI stellt der Kundin vor der Löschung für einen Zeitraum von **dreiBig (30) Tagen** die Möglichkeit zum **Export** der Daten in einem gängigen, strukturierten Format bereit. Nach Ablauf dieser Frist bzw. nach erfolgtem Export werden die Daten gelöscht.
- (3) NexAI bestätigt die Löschung auf Verlangen in **Textform** (Löschbestätigung).
- (4) Unterliegen Daten gesetzlichen Aufbewahrungspflichten (insbesondere § 147 AO, § 257 HGB), werden diese nicht gelöscht, sondern in ihrer Verarbeitung **eingeschränkt (gesperrt)** (Art. 18 DSGVO) und nach Ablauf der Aufbewahrungsfrist gelöscht.

Nachweis- und Kontrollrechte (Audit)

- (1) NexAI stellt der Kundin alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung und ermöglicht Überprüfungen – einschließlich Inspektionen –, die von der Kundin oder einem von ihr beauftragten Prüfer durchgeführt werden, und trägt zu diesen bei (Art. 28 Abs. 3 lit. h DSGVO).
- (2) Der Nachweis kann durch geeignete Dokumentation, aktuelle Testate, Zertifizierungen oder Berichte unabhängiger Stellen erbracht werden. Reichen diese zur Ausräumung eines konkreten Prüfbedarfs nicht aus, kann die Kundin nach rechtzeitiger Vorankündigung (in der Regel mindestens vierzehn (14) Tage vorab) und zu üblichen Geschäftszeiten eine Vor-Ort-Prüfung durchführen, ohne den Betriebsablauf unverhältnismäßig zu beeinträchtigen und unter Wahrung der Vertraulichkeit sowie der Rechte Dritter.
- (3) Der beauftragte Prüfer darf nicht in einem Wettbewerbsverhältnis zu NexAI stehen und ist zur Vertraulichkeit zu verpflichten.
- (4) Prüfungen, die über eine (1) reguläre Prüfung pro Jahr hinausgehen oder auf Verlangen der Kundin ohne konkreten Anlass erfolgen, kann NexAI den hierdurch entstehenden angemessenen Aufwand zu den üblichen Sätzen in Rechnung stellen. Prüfungen aus konkretem Anlass sowie die gesetzlich geschuldete Bereitstellung von Nachweisen bleiben hiervon unberührt.

Datenschutzbeauftragter, Verzeichnis, Kontaktstelle

- (1) NexAI benennt einen Datenschutzbeauftragten, sofern und soweit eine gesetzliche Benennungspflicht besteht. Kontaktstelle für Datenschutzangelegenheiten und für Weisungen nach § 4 Abs. 2 ist mbt@nex-a-i.com.
- (2) NexAI führt ein Verzeichnis aller Kategorien von im Auftrag durchgeführten Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).
- (3) Die Kundin führt ein eigenes Verzeichnis ihrer Verarbeitungstätigkeiten (Art. 30 Abs. 1 DSGVO). NexAI stellt ihr die dafür erforderlichen Angaben zum Terminkalender auf Anfrage zur Verfügung.

Haftung und Innenausgleich

- (1) Für die Haftung im Außenverhältnis gegenüber betroffenen Personen gilt Art. 82 DSGVO. Im Innenverhältnis tragen die Parteien einen etwaigen Schaden bzw. eine Geldbuße nach dem **Maß ihres jeweiligen Verantwortungsanteils** an dem zugrunde liegenden Verstoß.

- (2) Hat eine Partei an eine betroffene Person Schadensersatz geleistet, der über ihren Verantwortungsanteil hinausgeht, kann sie von der anderen Partei den auf deren Anteil entfallenden Teil zurückfordern.

Schlussbestimmungen

- (1) Änderungen und Ergänzungen dieses AVV bedürfen der Textform. Dies gilt auch für die Aufhebung dieses Textformerfordernisses. Vorrangige Individualabreden (§ 305b BGB) bleiben unberührt.
- (2) Sollte eine Bestimmung dieses AVV unwirksam sein oder werden, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.
- (3) Es gilt das Recht der Bundesrepublik Deutschland unter Ausschluss des UN-Kaufrechts.
- (4) Die Anhänge 1 (Technische und organisatorische Maßnahmen) und 2 (Unterauftragsverarbeiter) sind Bestandteil dieses AVV.

Anhang 1 — Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Beschreibt den Stand zum Zeitpunkt des Vertragsschlusses (September 2026).

1. Trennungskontrolle

- Der Terminkalender läuft auf einem eigenen, ausschließlich für die Kundin betriebenen Server; es werden dort keine Daten anderer Kunden verarbeitet.
- Eigene Datenbank; sämtliche Datensätze sind einem Betrieb zugeordnet, eine betriebsübergreifende Zusammenführung findet nicht statt.
- Entwicklung und Erprobung erfolgen auf getrennten Systemen mit erfundenen Testdaten, nicht mit Produktivdaten.

2. Zugangs- und Zugriffskontrolle

- Die Verwaltungsoberfläche ist vollständig durch Anmeldung geschützt; sämtliche Seiten sind ohne gültige Sitzung nicht erreichbar.
- Passwörter werden ausschließlich als bcrypt-Prüfsumme gespeichert, niemals im Klartext. Beim ersten Zugang wird ein Wechsel erzwungen.
- Sitzungskennungen liegen in der Datenbank nur als SHA-256-Abdruck; ein Auslesen der Datenbank erlaubt keine Übernahme einer Sitzung. Ein Passwortwechsel beendet alle übrigen Sitzungen.
- Anmeldeversuche sind je IP-Adresse und je Konto zahlenmäßig begrenzt (Schutz gegen Durchprobieren).
- Zugänge werden namentlich vergeben; nicht mehr benötigte Zugänge werden entzogen. Der letzte verbleibende Zugang ist gegen versehentliche Selbstsperrung geschützt.
- Der Zugang zum Server erfolgt ausschließlich über SSH-Schlüssel; Passwortanmeldung ist deaktiviert. Eine Firewall gibt nur die Dienste 22/80/443 frei, fail2ban sperrt auffällige Adressen, Sicherheitsaktualisierungen werden automatisch eingespielt.
- Eine Zwei-Faktor-Anmeldung für die Verwaltungsoberfläche ist derzeit nicht eingerichtet und für eine spätere Ausbaustufe vorgesehen.

3. Verschlüsselung und Weitergabekontrolle

- Sämtliche Übertragung erfolgt über TLS mit gültigem Zertifikat; HSTS ist aktiv, unverschlüsselte Aufrufe werden umgeleitet.
- Datensicherungen sind mit AES-256 verschlüsselt. Der private Schlüssel wird getrennt von den Sicherungen aufbewahrt und liegt auf keinem der beteiligten Server.
- Der Versand von SMS und E-Mail erfolgt über TLS-gesicherte Schnittstellen der jeweiligen Anbieter.
- Der Link, mit dem die Kundschaft ihren Termin selbst verschieben oder absagen kann, wird kryptografisch abgeleitet (HMAC) und nicht im Klartext gespeichert; er wird beim Verschieben ungültig und läuft nach dem Termin ab.
- Die Verwaltungsoberfläche verbietet die Einbettung in fremde Seiten; die Buchungsseite ist nur auf ausdrücklich freigegebenen Domains einbettbar.

4. Eingabe-, Integritäts- und Protokollierungskontrolle

- Wesentliche Änderungen an Terminen, Kundendaten und Einstellungen werden mit Zeitpunkt, handelnder Person und Art der Änderung protokolliert.

- Der Nachrichtenausgang hält je Bestätigung und Erinnerung fest, ob sie zugestellt wurde; ein Fehlversand ist nachvollziehbar.
- Die Datenbank selbst verhindert Doppelbuchungen durch eine Ausschlussbedingung; ein Zusammenstoß wird abgewiesen, nicht durch die Oberfläche kaschiert.
- Ausgestellte Belege und ihre Positionen sind durch Datenbankauslöser gegen Änderung und Löschung gesperrt (Unveränderbarkeit); zulässig ist allein der Vermerk eines Stornos.

5. Verfügbarkeit und Belastbarkeit

- Betrieb in einem Rechenzentrum der Hetzner Online GmbH in Deutschland.
- Tägliche Sicherung des gesamten Servers durch den Rechenzentrumsbetreiber.
- Zusätzlich nächtlich ein verschlüsselter Abzug der Datenbank auf einen zweiten Server in einem anderen deutschen Rechenzentrum, 30 Stände. Die Übertragung wird nach dem Kopieren auf Vollständigkeit geprüft.
- Die Wiederherstellung wird erprobt, nicht nur vorgehalten; zuletzt am 07.09.2026 vollständig auf einem anderen Server durchgespielt. Wiederholung mindestens vierteljährlich.
- Ein Wächter auf einem zweiten Server prüft alle 15 Minuten Erreichbarkeit, Zertifikatslaufzeit und das Alter der jüngsten Sicherung und meldet Abweichungen per E-Mail.

6. Datenminimierung und Löschung

- Von der Kundschaft werden nur Name und Telefonnummer verlangt; die E-Mail-Adresse ist freiwillig und wird im reinen SMS-Betrieb gar nicht erst abgefragt.
- Zahlungsdaten werden nicht erhoben. Der Terminkalender erfasst keine Zahlungsvorgänge.
- Das Anmerkungsfeld der Buchungsseite weist darauf hin, dort keine gesundheitsbezogenen Angaben zu machen.
- Die Löschrufen nach § 8 laufen als automatischer täglicher Vorgang; sie sind nicht von einer Handlung der Kundin abhängig.
- Die Kundin kann einzelne Kundendatensätze jederzeit selbst löschen oder anonymisieren und alle Daten als CSV bzw. ICS ausleiten.

7. Auftragskontrolle und Organisation

- Die Gesellschafter von NexAI sind unmittelbar zur Vertraulichkeit verpflichtet; weitere Personen werden vor einem Zugriff schriftlich verpflichtet.
- Die Unterauftragsverarbeiter sind vertraglich auf entsprechende Schutzpflichten gebunden (Anhang 2).
- Die Weisungslage ergibt sich aus diesem AVV und den weiteren Vertragsdokumenten; Einzelweisungen werden in Textform festgehalten.
- NexAI führt ein Verzeichnis der im Auftrag durchgeführten Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).

Anhang 2 — Unterauftragsverarbeiter

Die folgenden Unterauftragsverarbeiter sind zum Zeitpunkt des Vertragsschlusses eingesetzt und werden von der Kundin allgemein genehmigt (§ 9).

Name	Sitz / Land	Leistung	Datenkategorien	Grundlage
Hetzner Online GmbH	Gunzenhausen, Deutschland	Server, Speicherung und Rechenzentrumsbetrieb; Serversicherungen	alle im Terminkalender verarbeiteten Daten	AVV nach Art. 28 DSGVO; Verarbeitung ausschließlich in Deutschland
seven communications GmbH & Co. KG	Köln, Deutschland	Versand der Bestätigungs- und Erinnerungs-SMS	Rufnummer der Empfängerin, Inhalt der Nachricht (Name, Datum, Uhrzeit, Leistung)	AVV nach Art. 28 DSGVO; Verarbeitung ausschließlich in Deutschland

Derzeit ruhend: Für den Versand von E-Mails ist die Resend, Inc. (San Francisco, USA; EU-Verarbeitung in Irland) technisch hinterlegt. Im vereinbarten reinen SMS-Betrieb wird von der Kundschaft keine E-Mail-Adresse erhoben und an diesen Dienst folglich kein personenbezogenes Datum der Kundschaft übermittelt. Vor einer Umstellung auf E-Mail-Versand wird dieser Anhang nach § 9 Abs. 2 fortgeschrieben und der Transfermechanismus nach § 10 nachgewiesen.

Nicht als Unterauftragsverarbeitung gelten Nebenleistungen ohne Zugriff auf die Auftragsdaten (§ 9 Abs. 5). Sitzangaben und Grundlagen können sich ändern; maßgeblich ist die jeweils aktuelle, der Kundin nach § 9 Abs. 2 mitgeteilte Fassung.

Unterschriften

Die Parteien schließen diesen Vertrag zur Auftragsverarbeitung einschließlich seiner Anhänge 1 und 2 verbindlich ab.

Für NexAI

Für NexAI

Für die Kundin

Ort, Datum

Maximilian Trenk (Gesellschafter)

Ort, Datum

Jason Brian Merklein
(Gesellschafter)

Ort, Datum

Zsuzsanna Schatz

Dieser AVV ist ein sorgfältig erstellter Entwurf. Er ersetzt keine Rechtsberatung und sollte vor Verwendung anwaltlich geprüft werden.